

Security Testing

Authentication, authorization, sessions, OWASP, web and API security testing.

Security Testing for QA

Security Testing identifies risks that may compromise confidentiality, integrity, availability and access control. QA can include security checks without replacing security specialists.

Authentication vs authorization

Authentication answers who the user is; authorization defines what the user may do. Tests should cover credentials, sessions, expiration, roles, permissions and unauthorized access attempts.

OWASP as a reference

OWASP maintains widely used resources for web and API security risks and testing. They help structure checklists and technical learning.

Inputs and validation

Fields, parameters, headers and payloads should be treated as untrusted input. Validation, encoding and server-side controls are important for reducing vulnerability classes.

Sessions and tokens

Cookies, tokens, JWTs and sessions need appropriate expiration, protection and invalidation. Logout, password changes and privilege changes deserve specific scenarios.

API Security

Validate authentication, object/function authorization, rate limiting, excessive data exposure, error messages and behavior with manipulated payloads.

Tools

OWASP ZAP can support automated and manual dynamic analysis. Burp Suite is widely used for inspection and security testing. Tools do not replace risk understanding.

DevSecOps and Shift Left

Security can be incorporated into requirements, code review, dependency analysis, pipelines, testing and observability. Earlier discovery usually provides more remediation options.

QA tip

Never use real data or production credentials in public security examples.

Official resources

Site oficial: <https://wstg.owasp.org/>